MODULE 54 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Practice Exam: Domain 2

Fifteen original questions on security, compliance and governance.
Pause, decide, then watch.

DOMAIN 2 of 5 EXAM WEIGHT 25% SET 2 of 6

admin@sthithapragna.com

How to use this set

- **Allow 2.4 minutes per question**: 36 minutes for the set.
- **Write your answer down** before you unpause.
- **Watch for absolutes**: never, guarantee, any principal.
- The last slide maps every question to the module that teaches it.

> ON THE EXAM
>
> Security distractors are usually right about the control and wrong about who it applies to.

A company with 200 AWS accounts uses Microsoft Entra ID for its workforce. Staff must sign in once and reach any account they are entitled to.

Joiners and leavers must appear in AWS automatically, without scripts.

What should the solutions architect implement?

A. A SAML identity provider in each of the 200 accounts

B. IAM Identity Center with Entra ID as the external identity provider and SCIM provisioning

C. IAM users synchronised nightly from Entra ID

D. Amazon Cognito user pools federated with Entra ID

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A SAML per account

200 providers to maintain; no provisioning.

B Identity Center with SCIM

One sign-in, permission sets, automatic provisioning.

C Synced IAM users

Long-term credentials and a script.

D Cognito

For application users, not workforce access to AWS.

THE SIGNAL

Many accounts, workforce sign-in, automatic joiners and leavers: Identity Center with SCIM. Module 14.

A government agency is joining EC2 Windows instances to its on-premises Active Directory. Its security policy states that no directory data, including password hashes, may be stored in AWS.

Users must sign in with their existing domain credentials.

What should the solutions architect use?

A AWS Managed Microsoft AD with a trust to on-premises

B A read-only domain controller on EC2

C Simple AD

D AD Connector

◆ PAUSE AND DECIDE

What should the solutions architect use?

A Managed AD with trust

Stores a directory in AWS.

B RODC on EC2

Caches directory data in AWS.

C Simple AD

A separate directory in AWS; closed to new customers.

D AD Connector

A proxy: stores nothing, authenticates on premises.

THE SIGNAL

No directory data may live in AWS: AD Connector. Module 14.

A fitness app lets signed-in users upload workout videos from their phones directly to S3. Each user writes to a prefix named after their own user ID.

Users sign up with email or with Google.

What should the solutions architect use?

A. A Cognito user pool for sign-in, and a Cognito identity pool granting temporary credentials scoped to each user's prefix

B. An IAM user per app user

C. A Cognito user pool only, with the app calling S3 using the pool's tokens

D. Embed an access key in the mobile app

◆ PAUSE AND DECIDE

What should the solutions architect use?

A User pool plus identity pool

Sign-in, then scoped AWS credentials per user.

B IAM user each

Does not scale; long-term keys.

C User pool only

User pool tokens cannot sign S3 requests.

D Embedded key

Shared secret in every phone.

THE SIGNAL

Users calling AWS services directly, such as S3: add an identity pool. Module 15.

> An insurer has six microservices, each with its own copy of the rules deciding which brokers may view or amend which policies. The copies have drifted, and auditors cannot read them.
>
> The company wants one place to define and evaluate these rules.

What should the solutions architect recommend?

A IAM policies for each broker

B A shared library of authorisation code

C Amazon Verified Permissions, with the rules written as Cedar policies

D API Gateway resource policies

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A IAM per broker

IAM governs AWS APIs, not application records.

B Shared library

Still code, still unreadable, redeployed everywhere.

C Verified Permissions

Central, readable policies evaluated by every service.

D API resource policies

Coarse; cannot express per-record rules.

THE SIGNAL

The same rules duplicated across services, or auditors needing to read them: Verified Permissions. Module 15.

A third-party monitoring vendor needs read-only access to a company's AWS account. The vendor serves thousands of customers from its own AWS account.

The company wants to stop another of the vendor's customers from tricking the vendor into using the company's role.

What should the trust policy include?

A A condition requiring an ExternalId value unique to this company

B A condition on aws:SourceArn

C MFA required for the vendor

D A permissions boundary on the role

◆ PAUSE AND DECIDE

What should the trust policy include?

A ExternalId

Prevents the confused deputy for a vendor role.

B SourceArn

For AWS service principals, not a vendor account.

C Require MFA

The vendor's automation cannot do MFA.

D Permissions boundary

Limits permissions; does not stop misuse of the role.

THE SIGNAL

A vendor assuming your role: ExternalId. AWS service principals: SourceArn and SourceAccount. Module 16.

A platform team lets developers create IAM roles for their Lambda functions. A developer recently created a role with administrator access and used it.

Developers must keep creating roles, but no role they create may exceed a defined set of permissions.

What should the solutions architect implement?

A Remove iam:CreateRole from developers

B Allow role creation only when a specific permissions boundary is attached, and deny removing it

C An AWS Config rule that flags administrator roles

D A service control policy denying AdministratorAccess

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Remove CreateRole

Stops the work the team needs.

B Required permissions boundary

Every created role is capped by the boundary.

C Config rule

Detects after the fact.

D SCP on one policy

Blocks one policy; custom policies still escalate.

THE SIGNAL

Let teams create their own roles, but require a boundary on every role they create. Module 16.

A retailer's contractors need access to three internal web applications in a VPC. They must not get a VPN or network-level access.

Access must depend on the user's identity and on the posture of their device.

What should the solutions architect use?

A AWS Client VPN with security groups

B Make the applications public behind AWS WAF

C AWS Verified Access with identity and device trust providers

D A bastion host

◆ PAUSE AND DECIDE

What should the solutions architect use?

A Client VPN

Network access, which is ruled out.

B Public with WAF

Exposes the applications to the internet.

C Verified Access

Per-application, identity and device checks, no VPN.

D Bastion host

Network access and a host to run.

THE SIGNAL

Per-application access with device posture and no VPN: Verified Access. Module 17.

A bank's regulator requires that encryption keys for its data reside in single-tenant HSMs under the bank's exclusive control.

The bank still wants S3, EBS and RDS to encrypt data natively, with no application changes.

What should the solutions architect implement?

A AWS KMS with the default key store

B Client-side encryption in every application using CloudHSM

C SSE-S3 with versioning

D An AWS KMS custom key store backed by an AWS CloudHSM cluster

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Default KMS key store

Multi-tenant HSMs.

B Client-side with CloudHSM

Meets the HSM rule but changes every application.

C SSE-S3

AWS-owned keys.

D KMS custom key store

Keys in your CloudHSM; services use KMS as normal.

THE SIGNAL

Dedicated HSM plus native AWS service encryption: a custom key store. Module 18.

A medical device maker signs firmware updates. The devices will be in service for 20 years, and regulators expect signatures to stay trustworthy against future quantum computers.

The private key must never leave AWS-managed hardware.

What should the solutions architect use?

A An RSA-4096 signing key in AWS KMS

B An ML-DSA signing key in AWS KMS

C An ML-KEM key in AWS KMS

D An ECC P-384 signing key in AWS KMS

◆ PAUSE AND DECIDE

admin@sthithapragna.com

What should the solutions architect use?

A RSA-4096
Not quantum-resistant.

B ML-DSA
Post-quantum signatures, key held in KMS.

C ML-KEM
Key establishment, not signatures.

D ECC P-384
Not quantum-resistant.

THE SIGNAL

Proving origin or integrity: ML-DSA. Keeping data secret: ML-KEM. Module 19.

admin@sthithapragna.com

> No principal outside a company's organisation may ever access its S3 buckets or KMS keys, in any account. This must hold even if a developer writes a permissive bucket or key policy.
>
> Partners inside the organisation must keep access.

What should the solutions architect implement?

A. A resource control policy denying access unless aws:PrincipalOrgID matches the organisation

B. A service control policy on every OU

C. An AWS Config rule with automatic remediation

D. IAM Access Analyzer external access findings

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A RCP on PrincipalOrgID

Caps the resources, whatever their policies say.

B SCP on every OU

Governs your identities, not outsiders.

C Config remediation

Fixes after exposure.

D Access Analyzer

Reports exposure; does not prevent it.

THE SIGNAL

Outsiders reaching your resources: an RCP. Your own identities: an SCP. Module 20.

A financial group must keep CloudTrail logs from 80 accounts and every Region for seven years. Nobody, including administrators in the log archive account, may delete or alter them during that time.

Control Tower is deployed.

What should the solutions architect implement?

A. A trail in each account writing to its own bucket

B. CloudWatch Logs with seven-year retention in each account

C. An organisation trail to a bucket with S3 Object Lock in governance mode

D. An organisation trail to the log archive bucket with S3 Object Lock in compliance mode and a seven-year retention

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Trail per account

Local administrators can delete their logs.

B CloudWatch retention

Administrators can delete log groups.

C Object Lock governance

Privileged users can override governance mode.

D Object Lock compliance

Nobody can delete or shorten retention.

THE SIGNAL

Nobody, including administrators: compliance mode, not governance. Module 21.

A company patches EC2 instances in its Auto Scaling groups every month with Patch Manager. After each scale-out, new instances launch unpatched, and scanners flag them.

The company wants every instance compliant from the moment it launches.

What should the solutions architect change?

A Run Patch Manager every hour

B Disable scale-out between patch windows

C Build a patched AMI on a schedule, update the launch template, and roll it out with instance refresh

D Patch new instances with a user data script

◆ PAUSE AND DECIDE

What should the solutions architect change?

A Hourly patching
New instances still launch unpatched.

B Freeze scaling
Sacrifices availability.

C Patched AMI, instance refresh
Instances launch already patched.

D User data patching
Slow boots; a window before patching completes.

THE SIGNAL

Auto Scaling groups and containers: rebuild the image. Long-lived servers: patch in place. Module 22.

A hospital group's auditor asks for AWS's SOC 2 report and for the hospital's signed Business Associate Addendum with AWS.

The compliance team wants to provide both without opening a support case.

Where should the team get them?

A AWS Artifact

B AWS Audit Manager

C AWS Security Hub CSPM

D AWS Config conformance packs

◆ PAUSE AND DECIDE

Where should the team get them?

A AWS Artifact
AWS's reports and agreements, on demand.

B Audit Manager
Collects evidence of your controls; off the in-scope list.

C Security Hub CSPM
Your posture against standards.

D Conformance packs
Your configuration compliance.

THE SIGNAL

AWS's own certifications or a BAA: AWS Artifact. Proof of your controls: your own data. Module 23.

admin@sthithapragna.com

> An HR assistant built on Amazon Bedrock answers questions about leave entitlement. Answers must be checked against the written leave policy, and any answer that breaks a policy rule must be flagged.
>
> HR wants an explanation of which rule was broken.

What should the solutions architect configure?

A. A guardrail content filter for misconduct

B. Contextual grounding checks only

C. A larger model

D. Automated Reasoning checks in Amazon Bedrock Guardrails, built from the policy document

◆ PAUSE AND DECIDE

What should the solutions architect configure?

A Content filter

Harmful content, not policy logic.

B Contextual grounding

Checks support by sources; gives no rule-level explanation.

C Larger model

No verification at all.

D Automated Reasoning checks

Verifies against the rules, explains what failed.

THE SIGNAL

Verifiable against written rules, with an explanation of which rule failed: Automated Reasoning. Module 24.

A customer service agent on Amazon Bedrock can issue refunds. Refunds above 500 dollars must be approved by a supervisor, who may respond hours later.

If no supervisor responds within four hours, the request must escalate to a manager.

What should the solutions architect implement?

A. Ask the customer to confirm the refund in the chat

B. A guardrail that blocks refunds above 500 dollars

C. A Step Functions Standard workflow that pauses on a task token for the supervisor, with a timeout that escalates

D. Log large refunds for a weekly review

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Customer confirms
The customer is not the approver.

B Guardrail block
Blocks rather than routes for approval.

C Step Functions task token
Waits hours for a separate reviewer, then escalates.

D Weekly review
Approval after the money has gone.

THE SIGNAL

A separate reviewer, possibly hours later, with escalation: Step Functions with a task token. Module 24.

Where to revisit

IF YOU MISSED	REWATCH
Q1, Q2	Module 14: Identity and federation
Q3, Q4	Module 15: Application authentication
Q5, Q6	Module 16: Least privilege
Q7	Module 17: Data perimeters and zero trust
Q8, Q9	Modules 18-19: Encryption and post-quantum
Q10	Module 20: Organisation guardrails
Q11, Q12	Modules 21-22: Logging and patching
Q13	Module 23: Residency and evidence
Q14, Q15	Module 24: Responsible AI

ON THE EXAM

12 or more out of 15 is on track. Domain 2 is 25% of the exam, so gaps here cost the most.